

# ENGINEERING.md — AiduxCare V2

## Estándares de Ingeniería, Gobernanza de Código y Deuda Técnica

**\*\*Versión:\*\* 1.0**

**\*\*Fecha:\*\* Abril 2026**

**\*\*Autor:\*\* Mauricio Sobarzo (CEO/CTO, Fisioterapeuta)**

**\*\*Repositorio:\*\* `aiduxcare-stable` · Branch: `stable`**

---

> Este documento es la única fuente de verdad sobre cómo se construye, gobierna y mantiene el software de AiduxCare. Está diseñado para ser legible por desarrolladores humanos, auditores externos, inversores técnicos, y agentes de IA. Evoluciona con el producto.

---

## ## 1. Filosofía de Ingeniería

AiduxCare es un producto clínico de alta responsabilidad. Cada decisión de código tiene implicaciones para la seguridad del paciente, el cumplimiento regulatorio y la trazabilidad clínica. Esta filosofía guía todas las decisiones técnicas:

### **\*\*1.1 El código es evidencia clínica\*\***

El sistema genera, almacena y transmite notas clínicas que forman parte del historial médico del paciente. Un bug no es solo un fallo de software: puede ser una discrepancia en un registro médico. Esto eleva el estándar de calidad por encima del software de consumo genérico.

### **\*\*1.2 La autonomía clínica es no negociable\*\***

El sistema propone. El fisioterapeuta decide siempre. Ninguna función del sistema puede tomar decisiones clínicas en nombre del profesional, bloquear su juicio, ni generar documentación sin su revisión explícita. Esto no es solo un requisito de producto — es un principio ético y legal.

### **\*\*1.3 Mantenibilidad sobre velocidad\*\***

El código generado con asistencia de IA tiende a ser funcional pero arquitectónicamente débil si no se gobierna correctamente. La investigación de GitClear (2024-2025) analizando 211 millones de líneas de código documentó un aumento de 8x en bloques de código duplicado tras la adopción masiva de herramientas de IA, y una disminución de líneas "movidas" (reutilización) frente a líneas "copiadas". Este documento existe precisamente para contrarrestar esa tendencia.

**\*\*1.4 Deuda técnica documentada es deuda manejable\*\***

La deuda técnica no documentada es deuda oculta. Este documento registra toda la deuda conocida con criterio de cierre y responsable. Un inversor o CTO externo que haga due diligence encontrará aquí la verdad — no en el código.

---

## ## 2. Stack Tecnológico y Decisiones de Arquitectura

### ### 2.1 Stack principal

| Capa | Tecnología | Versión | Justificación |  
|---|---|---|---|  
| Frontend | React + TypeScript + Vite | React 18 | Tipado estático reduce errores clínicos en UI |  
| Backend / BaaS | Firebase (Firestore, Auth, Functions) | v11 | Compliance GDPR nativo, cifrado en reposo, escalabilidad |  
| IA Clínica | Vertex AI — Gemini 2.5 Flash | Gemini 2.5 | Latencia baja, razonamiento clínico, coste operativo |  
| Transcripción | OpenAI Whisper (gpt-4o-mini-transcribe) | GPT-4o | Precisión multilingüe, terminología clínica |  
| Deploy | GCP VPS + PM2 | — | Control total del entorno, trazabilidad de deploys |  
| SMS Consentimiento | Vonage (Cloud Function) | — | Trazabilidad de consentimiento digital RGPD |

### ### 2.2 Decisiones de arquitectura registradas (ADRs)

**\*\*ADR-001: Firestore como base de datos principal\*\***

**\*Contexto:\*** Sistema clínico con datos de pacientes protegidos bajo RGPD/PHIPA/PIPEDA.

**\*Decisión:\*** Firebase Firestore con reglas de seguridad a nivel de documento por `userId`.

**\*Consecuencia:\*** No hay acceso cruzado entre fisioterapeutas. Auditoría automática en `FirestoreAuditLogger`. Deuda: reglas de Firestore para sesiones legacy con `temp-user-` siguen siendo permisivas.

**\*\*ADR-002: Vertex AI para análisis clínico, no fine-tuning propio\*\***

**\*Contexto:\*** Riesgo de alucinaciones en contexto clínico.

**\*Decisión:\*** Prompt engineering con contexto profesional explícito + validación humana obligatoria antes de finalizar toda nota SOAP.

**\*Consecuencia:\*** El fisioterapeuta siempre revisa. El sistema nunca finaliza documentación sin aprobación.

**\*\*ADR-003: Deploy siempre desde Mac local\*\***

**\*Contexto:** Control de auditoría de versiones desplegadas.

**\*Decisión:** `VITE\_ENABLE\_ES\_PILOT=true npm run build` + gcloud SCP + pm2 restart. Nunca buildear en VPS.

**\*Consecuencia:** Trazabilidad completa de qué commit está en producción en cada momento.

**\*\*ADR-004: Un commit por fix, mensaje semántico\*\***

**\*Contexto:** Auditoría CPO (Ontario), due diligence de inversores.

**\*Decisión:** Conventional Commits (`fix:`, `feat:`, `chore:`). TSC limpio antes de cada commit.

**\*Consecuencia:** El historial de git es legible por un auditor externo sin contexto adicional.

---

## ## 3. Convenciones de Código

Estas reglas son **\*\*no negociables\*\*** y se aplican a todo el código, sea escrito por humanos o generado por agentes de IA.

### ### 3.1 Regla fundamental

```

One operation per line.

One intermediate variable per step.

```

Esta regla no es estética — es de auditoría. Cada línea debe poder leerse, revisarse y trackearse individualmente en un diff. Una línea que hace múltiples operaciones no puede auditarse con precisión.

**\*\*Incorrecto:\*\***

```typescript

```
const sessions = snapshot.docs.map((d) => ({ id: d.id, ...d.data() }));
```

```

**\*\*Correcto:\*\***

```typescript

```
const sessionDocs = snapshot.docs;
```

```
const sessions = sessionDocs.map((d) => {
```

```
  const sessionId = d.id;
```

```
  const sessionData = d.data();
```

```
const session = { id: sessionId, ...sessionData };  
return session;  
});  
`;
```

### ### 3.2 TypeScript estricto

- `pnpm exec tsc --noEmit` debe pasar con salida limpia antes de cualquier commit.
- No se permiten `any` sin comentario justificativo explícito.
- No se permiten `@ts-ignore` sin issue de backlog asociado.

### ### 3.3 Componentes

- No crear nuevos componentes sin autorización explícita del CEO/CTO.
- Cada componente nuevo requiere un briefing de diseño previo documentado.
- Reutilizar antes de crear.

### ### 3.4 Gestión de estado

- No usar `localStorage` para datos clínicos. Solo `SessionStorage` con scoping por `sessionId`.
- Los efectos secundarios deben tener cleanup explícito (especialmente listeners de Firestore y `setInterval`).
- Los `useEffect` deben declarar todas sus dependencias correctamente.

### ### 3.5 Seguridad

- Nunca hardcodear credenciales, API keys ni tokens en el código fuente.
- Toda comunicación con Firebase a través de reglas de seguridad por `userId`.
- Los logs de consola no deben incluir datos de pacientes (PHI). El sistema tiene `stripPHIFields` en analytics — aplicarlo consistentemente.

---

## ## 4. Proceso de Desarrollo con IA

AiduxCare utiliza desarrollo asistido por IA como práctica estándar. Este proceso está diseñado para capturar los beneficios de velocidad mientras mitiga los riesgos documentados por la industria.

### ### 4.1 Principio rector

> "Treat AI-generated output as a pull request." — BCG, 2025

El agente de IA implementa. El CTO humano decide la arquitectura, revisa el diff, y autoriza el commit. Ningún código generado por agente llega a producción sin revisión humana explícita.

### ### 4.2 Workflow estándar

...

1. CEO/CTO define el problema y el approach (Claude.ai — esta conversación)
  2. CEO/CTO elabora el briefing de implementación con restricciones explícitas
  3. Agente (Claude Code) implementa
  4. TSC verification: `pnpm exec tsc --noEmit 2>&1 | grep -v "web-vitals"`
  5. CEO/CTO revisa diff antes del commit
  6. Build + deploy + validación en pilot
  7. Commit semántico solo si validación pasa
- ...

### ### 4.3 Restricciones de briefing obligatorias

Todo briefing para un agente de IA debe incluir:

- Archivo(s) específico(s) a modificar
- Qué NO tocar
- Regla de codificación activa
- Comando de verificación TSC
- Instrucción explícita: "No build, no deploy, no commit"

### ### 4.4 CLAUDE.md

El archivo ``CLAUDE.md`` en la raíz del repositorio contiene las convenciones para el agente de IA. Según la documentación oficial de Anthropic, este archivo "va a cada sesión" y debe contener **\*\*únicamente instrucciones universalmente aplicables\*\***. Las instrucciones específicas de feature pertenecen a briefings ad-hoc, no a ``CLAUDE.md``.

> Nota: Investigación reciente de ETH Zurich (2026) muestra que los archivos de contexto para agentes tienen un impacto menor de lo esperado cuando los modelos son suficientemente capaces. El valor principal de ``CLAUDE.md`` no es técnico — es de gobernanza: fuerza la codificación del conocimiento institucional.

### ### 4.5 Sub-agentes de revisión (roadmap)

Siguiendo las mejores prácticas de la industria (proceso documentado en el ecosistema de Lanzadera y BCG, 2025), el siguiente nivel de madurez incluye sub-agentes especializados de revisión pre-commit:

- **Agente CTO:** revisión de arquitectura y deuda técnica
- **Agente Seguridad:** injection vulnerabilities, PHI exposure, Firestore rules
- **Agente CPO/Clínico:** coherencia del flujo clínico, autonomía del fisioterapeuta, compliance CPO/CGCFE

\*Estado actual:\* no implementado. Prioridad: Q3 2026.

---

## ## 5. Alineación ISO/IEC 25010:2023

La versión 2023 del estándar internacional de calidad de software añadió **safety** como característica de primer nivel, junto con escalabilidad e inclusividad como subcaracterísticas. Para AiduxCare, las nueve características se mapean así:

| Característica ISO 25010:2023 | Estado AiduxCare | Evidencia                                                                           |
|-------------------------------|------------------|-------------------------------------------------------------------------------------|
| Functional Suitability        | Activo           | SOAP generation, análisis clínico, consentimiento digital                           |
| Performance Efficiency        | Parcial          | Chunks >1MB en build (warning activo). Deuda: code splitting                        |
| Compatibility                 | Activo           | EMR-compatible SOAP output. Exportación PDF/TXT                                     |
| Interaction Capability        | Activo           | ES-ES completo en piloto España. Responsive. Accesibilidad pendiente                |
| Reliability                   | Activo           | Auto-save cada cambio. Backup en localStorage. Resume de sesiones                   |
| Security                      | Activo           | Firestore rules por userId. RGPD. Cifrado en reposo. PHI stripping en analytics     |
| Maintainability               | Parcial          | Convenciones documentadas. Deuda técnica registrada. Re-render loop pendiente       |
| Flexibility (Portabilidad)    | Activo           | React SPA. Deploy en cualquier servidor con Node. Multi-jurisdicción (ES/CA)        |
| Safety                        | Activo           | Validación CPO en SOAP. Alertas clínicas obligatorias. Autonomía del fisioterapeuta |

---

## ## 6. Compliance y Seguridad de Datos Clínicos

### ### 6.1 Marco regulatorio activo

| Marco | Jurisdicción | Estado | Evidencia en código |  
|---|---|---|---|  
| RGPD / LOPDGDD | España (UE) |  Implementado | Consentimiento digital trazado. Datos en Firestore EU. SMS con token de 7 días |  
| PHIPA | Ontario, Canadá |  Arquitectura | Reglas Firestore por userId. Audit log. Consentimiento verificado antes de acceso clínico |  
| PIPEDA | Canadá federal |  Arquitectura | Cifrado en reposo. Acceso por rol. Retención de datos configurable |  
| Ley 41/2002 | España |  Implementado | Consentimiento informado previo. Historia clínica trazable |  
| CGCFE | España |  Parcial | Validación SOAP por estándares fisioterapia. Número de colegiado en informes |  
| CPO Ontario | Canadá |  Parcial | SOAP validation. Compliance block modal. Audit-ready encounters |

### ### 6.2 Roadmap de certificaciones

El camino de certificación para un healthtech que opera en España con expansión a Canadá sigue esta progresión natural, confirmada por auditores como Bureau Veritas, BSI Group y Schellman:

...

[ACTUAL]    RGPD/LOPDGDD + PHIPA/PIPEDA (arquitectura)  
[Q4 2026]    ISO/IEC 27001 — Information Security Management System  
[2027]       SOC 2 Type II (requerido para venta a clínicas enterprise en Norteamérica)  
[2027+]      ISO 42001 — AI Management System (gobernanza de IA en contexto clínico)  
...

> ISO 27001 es el punto de entrada lógico porque construye sobre el trabajo de RGPD ya realizado. Según investigación de Assuric (2025): "Si ya cumples con GDPR, estás en una posición excelente para iniciar ISO 27001 — construye sobre el trabajo existente en lugar de empezar desde cero."

> El costo estimado para una startup en etapa Seed-Series A para ISO 27001 oscila entre \$30k-\$60k incluyendo implementación y auditoría (RiscLens, 2026).

### ### 6.3 Controles técnicos de seguridad activos

- **Autenticación:** Firebase Auth con verificación de email
- **Autorización:** Reglas Firestore por `userId` en cada colección
- **Auditoría:** `FirestoreAuditLogger` registra eventos críticos con timestamp y

userId

- **PHI:** `stripPHIFields` en analytics. Logs de consola sin datos de pacientes
- **Consentimiento:** Token de 7 días con URL única. Estado persistido en Firestore
- **Cifrado:** En reposo (Firestore default). En tránsito (HTTPS forzado)

---

## ## 7. Deuda Técnica Documentada

La deuda técnica no documentada es el mayor riesgo de mantenibilidad en software generado con IA. Esta tabla es la fuente de verdad. Toda deuda conocida está aquí.

### ### 7.1 Deuda técnica activa

| ID     | Descripción                                                                             | Severidad | Origen       | Criterio de cierre                                                    |
|--------|-----------------------------------------------------------------------------------------|-----------|--------------|-----------------------------------------------------------------------|
| TD-001 | Re-render loop en `EvaluationTab` al escribir notas de tests                            | Media     | Agente IA    | Eliminar escrituras innecesarias a Firestore en cada keystroke        |
| TD-002 | Sesiones legacy `temp-user-...` no actualizables en Firestore                           | Baja      | Histórico    | Migración de datos o exclusión explícita del query                    |
| TD-003 | `mskTestLibrary.ts` — 38 tests en inglés                                                | Media     | Histórico    | Traducción ES-ES con revisión clínica de terminología                 |
| TD-004 | Motor ES de informe de derivación no conectado a UI                                     | Baja      | Arquitectura | Wiring de `clinicalReportService.ts` al modal de informe              |
| TD-005 | Chunks >1MB en build (Vite warning)                                                     | Baja      | Arquitectura | `manualChunks` en `vite.config.ts` para code splitting                |
| TD-006 | `VoiceInputButton` no disponible en tests manuales de biblioteca                        | Media     | Agente IA    | Unificar renderizado de campos entre tests IA y tests manuales        |
| TD-007 | `lastName` no hidratado desde `users/{uid}` en perfil profesional                       | Baja      | Datos        | Migración de datos o derivación desde `fullName` (fix parcial activo) |
| TD-008 | Pre-población de tests desde transcripción no implementada                              | Alta      | (feature)    | Roadmap                                                               |
|        | Implementar `extracted_measurements` en prompt de análisis + binding en `EvaluationTab` |           |              |                                                                       |

### ### 7.2 Deuda de producto (no código)

| ID     | Descripción                                    | Dueño | Decisión pendiente     |
|--------|------------------------------------------------|-------|------------------------|
| PD-001 | Consentimiento escrito sin opción de impresión | CEO   | Flujo alternativo o QR |



| **\*\*PD-002\*\*** | Certificados y email de actualización al paciente | CEO | Gap funcional — requiere sprint dedicado |  
| **\*\*PD-003\*\*** | Edición de datos del paciente — UX/discoverability | CEO | Añadir acceso desde command center |  
| **\*\*PD-004\*\*** | Consentimiento tutores/menores/incapacidad | CEO | Fuera de scope piloto actual |

---

## ## 8. Handoff Readiness

Un desarrollador técnico externo debe poder arrancar en menos de 30 minutos con este documento y el repositorio. Esta sección lo garantiza.

### ### 8.1 Prerrequisitos

```
```bash
node --version # >= 18
pnpm --version # >= 8
gcloud --version # Google Cloud SDK configurado con proyecto aiduxcare-v2-uat-dev
```
```

### ### 8.2 Setup local

```
```bash
git clone https://github.com/Maurosg78/AIDUXCARE-V.2 aiduxcare-stable
cd aiduxcare-stable
git checkout stable
pnpm install
cp .env.example .env.local # Variables de Firebase — solicitar al CEO
pnpm dev
```
```

### ### 8.3 Verificación de calidad

```
```bash
# TypeScript — debe salir limpio
pnpm exec tsc --noEmit 2>&1 | grep -v "web-vitals"
```

```
# Build de producción
VITE_ENABLE_ES_PILOT=true npm run build
```
```

### ### 8.4 Deploy a producción

```
```bash
VITE_ENABLE_ES_PILOT=true npm run build && \
gcloud compute ssh pilot-vps --command="rm -rf /var/www/pilot/dist/*" && \
gcloud compute scp --recurse dist/* pilot-vps:/var/www/pilot/dist/ && \
gcloud compute ssh pilot-vps --command="pm2 restart pilot-web"
```
```

**\*\*Regla:\*\*** Nunca buildear en el VPS. Siempre desde Mac local.

### ### 8.5 Colecciones Firestore principales

| Colección                     | Propósito                             | Acceso                    |
|-------------------------------|---------------------------------------|---------------------------|
| ---                           | ---                                   | ---                       |
| `users/{uid}`                 | Perfil profesional del fisioterapeuta | Solo el propio usuario    |
| `patients/{patientId}`        | Datos del paciente                    | userId del fisioterapeuta |
| `notes/{noteId}`              | Notas SOAP guardadas                  | userId del fisioterapeuta |
| `sessions/{sessionId}`        | Estado de sesión clínica              | userId del fisioterapeuta |
| `encounters/{encounterId}`    | Encuentros completados (longitudinal) | userId del fisioterapeuta |
| `patient_trajectory_events`   | Eventos de trayectoria clínica        | userId del fisioterapeuta |
| `patient_consent/{patientId}` | Estado de consentimiento              | userId del fisioterapeuta |
| `user_feedback`               | Feedback de usuarios del piloto       | Admin only                |

---

## ## 9. Fuentes y Referencias

Este documento está fundamentado en los siguientes estándares y publicaciones:

1. **\*\*ISO/IEC 25010:2023\*\*** — Systems and software Quality Requirements and Evaluation (SQuaRE). International Organization for Standardization. Noviembre 2023. <https://www.iso.org/standard/78176.html>
2. **\*\*GitClear AI Copilot Code Quality Report 2024-2025\*\*** — Análisis de 211 millones de líneas de código. Documenta el aumento de 8x en duplicación de código y la disminución de reutilización en codebases con IA. <https://www.gitclear.com/>
3. **\*\*Google DORA Report 2024\*\*** — "A 25% increase in AI usage quickens code

reviews and benefits documentation, but results in a 7.2% decrease in delivery stability." Citado en LeadDev, agosto 2025.

4. **Ox Security — Army of Juniors: The AI Code Security Crisis (2025)** — "AI-generated code is highly functional but systematically lacking in architectural judgment." <https://www.infoq.com/news/2025/11/ai-code-technical-debt/>

5. **BCG X — From Dev Speed to Business Impact (2025)** — "Treat AI-generated output as a pull request. Encourage a lead engineer mindset at every level." <https://www.bcg.com/x/the-multiplier/ai-assisted-coding-generative-engineering>

6. **Sonar — State of Code Developer Survey 2026** — "72% of developers who use AI coding tools rely on them daily. 42% of committed code is AI-assisted." <https://www.sonarsource.com/state-of-code-developer-survey-report.pdf>

7. **Anthropic — Claude Code Best Practices (2025-2026)** — CLAUDE.md, subagents, skills authoring. <https://code.claude.com/docs/en/best-practices>

8. **ETH Zurich — Context files for coding agents (2026)** — Documenta que los archivos AGENTS.md/CLAUDE.md tienen impacto limitado (5% sobre baseline) con modelos de frontera actuales. El valor es de gobernanza, no solo técnico. Citado en XDA Developers, 2026.

9. **Assuric — SOC 2 for Healthtech (2025)** — Roadmap de certificaciones para healthtech: GDPR → ISO 27001 → SOC 2. <https://www.assuric.com/blog/soc2-compliance-for-healthtech>

10. **Sekurno — ISO 27001 for Biotech & HealthTech (2025)** — "Trusted ISO 27001 auditors: BSI Group, NQA, Schellman, and Bureau Veritas." <https://www.sekurno.com/post/iso-27001-compliance-checklist-for-biotech-and-healthtech-2025>

11. **RiscLens — ISO 27001 Audit Preparation for HealthTech Startups (2026)** — "Most HealthTech companies at Seed to Series A stage spend between \$30k-\$60k on their initial ISO 27001 audit." <https://risclens.com/iso-27001/iso-27001-audit-prep/healthtech>

12. **HumanLayer — Writing a good CLAUDE.md (2025)** — "CLAUDE.md should contain as few instructions as possible — ideally only ones which are universally applicable." <https://www.humanlayer.dev/blog/writing-a-good-claude-md>

---

## 10. Control de Versiones de este Documento

| Versión   Fecha   Cambios                                 |
|-----------------------------------------------------------|
| --- --- ---                                               |
| 1.0   Abril 2026   Versión inicial. Piloto España activo. |

---

\*AiduxCare V2 — Documento interno de ingeniería. No contiene datos de pacientes.\*